

Módulo 3: Identidad y Control de Acceso

T09: Cookies, CSRF y Session Hijacking

Carlos Rodríguez Contreras · GitHub: [karrocon](#)

 *Flags de cookies, tokens CSRF y el robo de sesión*

Objetivos

- Entender los flags de cookies: `HttpOnly`, `Secure`, `SameSite`
- Explicar cómo funciona un ataque CSRF y por qué es peligroso
- Demostrar el robo de cookie de sesión mediante XSS en VulnApp
- Implementar tokens CSRF y flags de cookie correctos como defensa

En construcción

Este topic todavía no tiene slides completas.

Usa las diapositivas maestras (`slides-curso.html`) como referencia del contenido previsto.

Lab T09: Robo de sesión por cookie sin HttpOnly

Objetivo: demostrar que una cookie sin `HttpOnly` puede ser robada por XSS

Setup: `cd VulnApp && npm start`

1. Inicia sesión y mira la cookie de sesión en DevTools
2. Observa que no tiene el flag `HttpOnly`
3. Usa el payload XSS del T05 para imprimir `document.cookie`
4. Añade `httpOnly: true` y `sameSite: 'strict'` en la config de sesión
5. Verifica que `document.cookie` ya no devuelve la cookie de sesión